

TECNOLOGIA DA INFORMAÇÃO

Gestão de Segurança da
Informação: Norma NBR ISO/IEC
n. 27002:2022



Presidente: Gabriel Granjeiro

Vice-Presidente: Rodrigo Calado

Diretor Pedagógico: Erico Teixeira

Diretora de Produção Educacional: Vivian Higashi

Gerente de Produção Digital: Bárbara Guerra

Coordenadora Pedagógica: Élica Lopes

Todo o material desta apostila (incluindo textos e imagens) está protegido por direitos autorais do Gran. Será proibida toda forma de plágio, cópia, reprodução ou qualquer outra forma de uso, não autorizada expressamente, seja ela onerosa ou não, sujeitando-se o transgressor às penalidades previstas civil e criminalmente.

CÓDIGO:

241114101935



PATRÍCIA QUINTÃO

Mestre em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV. Atualmente é professora no Gran Cursos Online; Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG; Escritora e Personal & Professional Coach. Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008. É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação. Autora dos livros: Informática FCC - Questões comentadas e organizadas por assunto, 3ª. edição e 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método. Foi aprovada nos seguintes concursos: Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG; Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia; Professora substituta do DCC da UFJF; Analista de TI/Suporte, PRODABEL; Analista do Ministério Público MG; Analista de Sistemas, DATAPREV, Segurança da Informação; Analista de Sistemas, INFRAERO; Analista - TIC, PRODEMGE; Analista de Sistemas, Prefeitura de Juiz de Fora; Analista de Sistemas, SERPRO; Analista Judiciário (Informática), TRF 2ª Região RJ/ES, etc.

GRAN
CONCURSOS

SUMÁRIO

Apresentação	7
Gestão de Segurança da Informação: Norma NBR ISO/IEC n. 27002:2022	8
Introdução	8
1. Escopo	9
2. Referência Normativa	9
3. Alguns Termos e Definições	9
4. Estrutura da Norma	10
5. Controles Organizacionais	12
5.1. Políticas de segurança da informação	12
5.2. Papéis e Responsabilidades pela Segurança da Informação	13
5.3. Segregação de Funções	13
5.4. Responsabilidades da Direção	13
5.5. Contato com Autoridades	13
5.6. Contato com Grupos de Interesse Especial	13
5.7. Inteligência de Ameaças	14
5.8. Segurança da Informação no Gerenciamento de Projetos	14
5.9. Inventário de Informações e Outros Ativos Associados	14
5.10. Uso Aceitável de Informações e Outros Ativos Associados	15
5.11. Devolução de Ativos	15
5.12. Classificação das Informações	15
5.13. Rotulagem de Informações	15
5.14. Transferência de Informações	16
5.15. Controle de Acesso	18
5.16. Gestão de Identidade	18
5.17. Informações de Autenticação	18
5.18. Direitos de Acesso	19
5.19. Segurança da Informação nas Relações com Fornecedores	19

5.20. Abordagem da Segurança da Informação nos Contratos de Fornecedores	19
5.21. Gestão da Segurança da Informação na Cadeia de Fornecimento de TIC.	19
5.22. Monitoramento, Análise Crítica e Gestão de Mudanças dos Serviços de Fornecedores	20
5.23. Segurança da Informação para Uso de Serviços em Nuvem	20
5.24. Planejamento e Preparação da Gestão de Incidentes de Segurança da Informação	20
5.25. Avaliação e Decisão sobre Eventos de Segurança da Informação	20
5.26. Resposta a Incidentes de Segurança da Informação	21
5.27. Aprendizado com Incidentes de Segurança da Informação	21
5.28. Coleta de Evidências.	21
5.29. Segurança da Informação Durante a Disrupção	21
5.30. Prontidão de TIC para Continuidade de Negócios	21
5.31. Requisitos Legais, Estatutários, Regulamentares e Contratuais	22
5.32. Direitos de Propriedade Intelectual	22
5.33. Proteção de Registros	22
5.34. Privacidade e Proteção de DP	22
5.35. Análise Crítica Independente da Segurança da Informação	23
5.36. Conformidade com Políticas, Regras e Normas para Segurança da Informação	23
5.37. Documentação dos Procedimentos de Operação.	23
6. Controles de Pessoas	23
6.1. Seleção	23
6.2. Termos e Condições de Contratação	24
6.3. Conscientização, Educação e Treinamento em Segurança da Informação	24
6.4. Processo Disciplinar	24
6.5. Responsabilidades após Encerramento ou Mudança da Contratação	25
6.6. Acordos de Confidencialidade ou Não Divulgação	25
6.7. Trabalho Remoto.	25

6.8. Relato de Eventos de Segurança da Informação.	25
7. Controles Físicos.	26
7.1. Perímetros de Segurança Física	26
7.2. Entrada física	26
7.3. Segurança de Escritórios, Salas e Instalações.	26
7.4. Monitoramento de Segurança Física	26
7.5. Proteção Contra Ameaças Físicas e Ambientais	27
7.6. Trabalho em Áreas Seguras	27
7.7. Mesa Limpa e Tela Limpa	27
7.8. Localização e Proteção de Equipamentos	27
7.9. Segurança de Ativos Fora das Instalações da Organização	27
7.10. Mídia de Armazenamento	28
7.11. Serviços de Infraestrutura	28
7.12. Segurança do Cabeamento	28
7.13. Manutenção de Equipamentos	28
7.14. Descarte Seguro ou Reutilização de Equipamentos.	29
8. Controles Tecnológicos	29
8.1. Dispositivos Endpoint do Usuário.	29
8.2. Direitos de Acessos Privilegiados	29
8.3. Restrição de Acesso à Informação	31
8.4. Acesso ao Código-Fonte.	31
8.5. Autenticação Segura	31
8.6. Gestão de Capacidade	31
8.7. Proteção Contra Malware.	31
8.8. Gestão de Vulnerabilidades Técnicas	32
8.9. Gestão de Configuração.	32
8.10. Exclusão de Informações	32
8.11. Mascaramento de Dados	32

8.12. Prevenção de Vazamento de Dados	33
8.13. Backup das Informações	33
8.14. Redundância dos Recursos de Tratamento de Informações	33
8.15. Log	33
8.16. Atividades de Monitoramento.	34
8.17. Sincronização do Relógio	34
8.18. Uso de Programas Utilitários Privilegiados	34
8.19. Instalação de Software em Sistemas Operacionais	34
8.20. Segurança de Redes	34
8.21. Segurança dos Serviços de Rede.	35
8.22. Segregação de Redes	35
8.23. Filtragem da Web	35
8.24. Uso de Criptografia	35
8.25. Ciclo de Vida de Desenvolvimento Seguro.	36
8.26. Requisitos de Segurança da Aplicação	36
8.27. Princípios de Arquitetura e Engenharia de Sistemas Seguros	36
8.28. Codificação Segura	36
8.29. Testes de Segurança em Desenvolvimento e Aceitação	36
8.30. Desenvolvimento Terceirizado	37
8.31. Separação dos Ambientes de Desenvolvimento, Teste e Produção	37
8.32. Gestão de Mudanças	37
8.33. Informações de Teste.	37
8.34. Proteção de Sistemas de Informação Durante os Testes de Auditoria . . .	38
Resumo	39
Exercícios	41
Gabarito	47
Gabarito Comentado.	48
Referências	62

APRESENTAÇÃO

Olá, meu caro(a) amigo(a)! Espero que esteja bem.

Vamos juntos explorar a **Norma ABNT NBR ISO/IEC 27002:2022 - Segurança da informação, segurança cibernética e proteção à privacidade — Controles de segurança da informação**.

Esta norma cancela e substitui a ABNT NBR ISO/IEC 27002:2012, trazendo atualizações importantes.

Mantenha o **FOCO** e a **DETERMINAÇÃO** nos seus estudos! Se surgir alguma dúvida, não hesite em visitar o fórum do curso ou entrar em contato.

Um grande abraço,

Profª Patrícia Quintão

Instagram: @patricialquintao

GESTÃO DE SEGURANÇA DA INFORMAÇÃO: NORMA NBR ISO/IEC N. 27002:2022

INTRODUÇÃO

- A **Norma ABNT NBR ISO/IEC 27002:2022** é projetada para ser usada como **referência para determinar e implementar controles para tratamento de riscos de segurança da informação em um sistema de gestão de segurança da informação (SGSI)** baseado na ABNT NBR ISO/IEC 27001.
- Também pode ser usada como um **documento de orientação para organizações determinando e implementando controles de segurança da informação comumente aceitos**.
- Controles organizacionais ou específicos do ambiente que não sejam os incluídos neste documento podem ser determinados por meio do processo de avaliação de riscos, conforme necessário.
- **Organizações de todos os tipos e tamanhos (incluindo o setor privado e público, comercial e sem fins lucrativos)**, criam, coletam, tratam, armazenam, transmitem e descartam informações de diversas formas, incluindo eletrônica, física e verbal (por exemplo, conversas e apresentações).
- A **SI é alcançada pela implementação de um conjunto adequado de controles**, incluindo políticas, regras, processos, procedimentos, estruturas organizacionais e funções de software e hardware.
- É essencial que uma organização determine os seus requisitos de SI. Existem **três fontes principais de requisitos de SI**:
 - **avaliação de riscos da organização**, considerando a estratégia e os objetivos globais de negócios da organização;
 - os **requisitos legais, estatutários, regulamentares e contratuais** que uma organização e suas partes interessadas (parceiros comerciais, prestadores de serviços etc.) têm que cumprir e seu ambiente sociocultural;
 - o **conjunto de princípios, objetivos e requisitos de negócios** para todas as etapas do ciclo de vida de informações que uma organização desenvolveu para apoiar suas operações.
- Um controle é definido como uma medida que modifica ou mantém o risco. Alguns dos controles deste documento são controles que modificam o risco, enquanto outros mantêm o risco.
- **Nem todos os controles e orientações deste documento podem ser aplicáveis a todas as organizações.**

- Controles e diretrizes adicionais não incluídas neste documento também podem ser necessários para atender às necessidades específicas da organização e aos riscos identificados.

1. ESCOPO

A **Norma NBR ISO/IEC 27002:2022** oferece um conjunto de controles genéricos de segurança da informação como referência, além de orientações para sua implementação.

Esta Norma é destinada ao uso por **organizações**:

- no contexto de um sistema de gestão de segurança da informação (SGSI) conforme a ABNT NBR ISO/IEC 27001;
- para implementar controles de segurança da informação baseados em práticas reconhecidas internacionalmente;
- para desenvolver diretrizes específicas de gestão de segurança da informação dentro da organização.

2. REFERÊNCIA NORMATIVA

Não existem referências normativas neste documento.

3. ALGUNS TERMOS E DEFINIÇÕES

Veja a relação de termos a seguir:

Ameaça	Causa potencial de um incidente indesejado, que pode resultar em danos a um sistema ou organização.
Ataque	Tentativa não autorizada, bem-sucedida ou malsucedida, de destruir, alterar, desabilitar, obter acesso a um ativo ou qualquer tentativa de expor, roubar ou fazer uso não autorizado de um ativo.
Ativo	Qualquer coisa que tenha valor para a organização.
Autenticação	Provisão de garantia de que uma característica alegada de uma entidade está correta.
Controle	Medida que mantém e/ou modifica o risco.
Controle de acesso	Assegurar que o acesso físico e lógico aos ativos seja autorizado e restrito com base em requisitos de negócio e de segurança da informação.
Dados pessoais (DP)	Qualquer informação que (a) possa ser usada para identificar a pessoa natural à qual tal informação se relaciona ou (b) é ou pode ser direta ou indiretamente vinculada a uma pessoa natural.
Disrupção	Incidente, seja previsto ou imprevisto, que causa um desvio, não planejado e negativo da expectativa de entrega de produtos e serviços de acordo com os objetivos da organização.
Evento de segurança da informação	Ocorrência indicando uma possível violação de segurança da informação ou falha de controles.

Incidente de segurança da informação	Um ou múltiplos eventos de segurança da informação relacionados e identificados que podem prejudicar os ativos da organização ou comprometer suas operações.
Informações sensíveis	Informações que precisam ser protegidas contra indisponibilidade, acesso, modificação ou divulgação pública não autorizada devido a potenciais efeitos adversos em um indivíduo, organização, segurança nacional ou segurança pública.
Single Sign On (SSO)	Processo de autenticação que permite o acesso a diversos sistemas com o uso das mesmas credenciais de acesso.
Vulnerabilidade	Fraqueza de um ativo ou controle que pode ser explorado por uma ou mais ameaças.
Wipe	Método que visa destruir completamente todos os dados que residem em uma unidade de disco rígido ou outra mídia digital, usando "0 e 1" para sobrescrever os dados em todos os setores do dispositivo, em um processo irreversível.

4. ESTRUTURA DA NORMA

As principais seções da **norma ABNT NBR ISO IEC 27002:2022** estão destacadas a seguir:

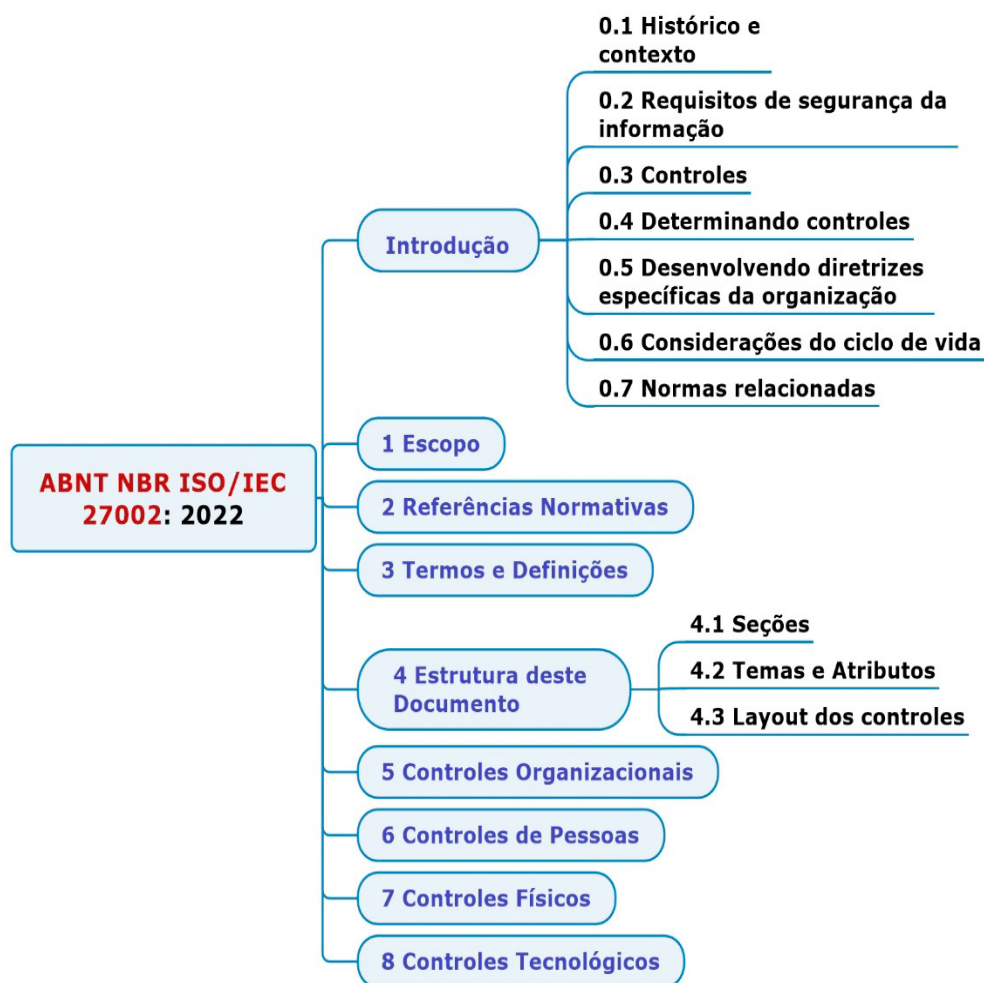


Figura. Seções da norma ABNT NBR ISO IEC 27002:2022 (QUINTÃO, 2024)

Atenção especial às seções:

- **Controles organizacionais** (Seção 5).
- **Controles de pessoas** (Seção 6).
- **Controles físicos** (Seção 7).
- **Controles tecnológicos** (Seção 8).

Na norma existem ainda dois anexos informativos:

Anexo A – Uso de atributos	Explica como uma organização pode usar atributos para criar suas próprias visões com base nos atributos de controle definidos neste documento ou de sua própria criação.
Anexo B – Correspondência com a ABNT NBR ISO/IEC 27002:2013	Mostra a correspondência entre os controles nesta edição da ABNT NBR ISO/IEC 27002 e da edição anterior de 2013.

A **categorização dos controles** dados nas Seções 5 a 8 é referida como temas.

Os **controles** são categorizados como:

- a) **pessoas**, se eles dizem respeito a pessoas individuais;
- b) **físico**, se eles dizem respeito a objetos físicos;
- c) **tecnológico**, se eles dizem respeito à tecnologia;
- d) caso contrário, eles são categorizados como **organizacionais**.

A ordem das seções **não** segue um grau de importância, **ficando a cargo de cada organização identificar as seções aplicáveis e a relevância de cada uma**.

DIRETO DO CONCURSO

001. (FEPESE/ANALISTA (CELESC)/SISTEMAS/INFRAESTRUTURA OPERAÇÃO SEGURANÇA/2022)

Quais grupos de controle são definidos pela ISO 27002:2022, após a última atualização?

1. Pessoas
2. Físicos
3. Virtuais
4. Tecnológicos
5. Organizacionais

Assinale a alternativa que indica todas as afirmativas corretas.

- a) São corretas apenas as afirmativas 1, 4 e 5.
- b) São corretas apenas as afirmativas 2, 4 e 5.
- c) São corretas apenas as afirmativas 1, 2, 3 e 4.

- d) São corretas apenas as afirmativas 1, 2, 4 e 5.
e) São corretas apenas as afirmativas 2, 3, 4 e 5.



A norma **ABNT NBR ISO/IEC 27002:2022** organiza os controles de segurança da informação em grupos, que incluem:

- **Controles de Pessoas:** relacionados à segurança de recursos humanos, como seleção, conscientização e treinamento.
- **Controles Físicos:** envolvem medidas para proteger fisicamente as instalações e equipamentos.
- **Controles Tecnológicos:** focados em proteger informações através de tecnologias, como criptografia e controle de acesso.
- **Controles Organizacionais:** abrangem políticas, procedimentos e responsabilidades para gerenciar a segurança da informação.

Conforme visto, estão corretos:

1. Pessoas

2. Físicos

~~**3. Virtuais**~~

4. Tecnológicos

5. Organizacionais

Com base nesses grupos, a alternativa correta que indica todas as afirmativas corretas é:

D) São corretas apenas as afirmativas 1, 2, 4 e 5.

Letra d.

5. CONTROLES ORGANIZACIONAIS

5.1. POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que a política de segurança da informação e as políticas específicas por tema sejam definidas, aprovadas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e partes interessadas pertinentes, e analisadas criticamente em intervalos planejados e se ocorrer mudanças significativas.

Propósito

Assegurar a adequação contínua, suficiência, efetividade da direção de gestão e suporte à segurança da informação de acordo com os requisitos comerciais, legais, estatutários, regulamentares e contratuais.

5.2. PAPÉIS E RESPONSABILIDADES PELA SEGURANÇA DA INFORMAÇÃO

Controle

Convém que os papéis e responsabilidades pela segurança da informação sejam definidos e alocados de acordo com as necessidades da organização.

Propósito

Estabelecer uma estrutura definida, aprovada e compreendida para a implementação, operação e gestão da segurança da informação dentro da organização.

5.3. SEGREGAÇÃO DE FUNÇÕES

Controle

Convém que funções conflitantes e áreas de responsabilidade sejam segregados.

Propósito

Reduzir o risco de fraude, erro e desvio de controles de segurança da informação.

5.4. RESPONSABILIDADES DA DIREÇÃO

Controle

Convém que a direção requeira que todo o pessoal aplique a segurança da informação de acordo com a política de segurança da informação estabelecida, com as políticas específicas por tema e com os procedimentos da organização.

Propósito

Assegurar que a direção entenda seu papel na segurança da informação e realize ações com o objetivo de assegurar que todo o pessoal esteja ciente e cumpra suas responsabilidades pela segurança da informação.

5.5. CONTATO COM AUTORIDADES

Controle

Convém que a organização estabeleça e mantenha contato com as autoridades relevantes.

Propósito

Assegurar o fluxo adequado de informações referentes à segurança da informação entre a organização e as autoridades legais, regulatórias e fiscalizadoras relevantes.

5.6. CONTATO COM GRUPOS DE INTERESSE ESPECIAL

Controle

Convém que a organização estabeleça e mantenha contato com grupos de interesse especial ou outros fóruns de especialistas em segurança e associações profissionais.

Propósito

Assegurar que ocorra o fluxo adequado de informações relacionadas à segurança da informação.

5.7. INTELIGÊNCIA DE AMEAÇAS

Controle

Convém que as informações relacionadas a ameaças à segurança da informação sejam coletadas e analisadas para produzir inteligência de ameaças.

Propósito

Conscientizar sobre o ambiente de ameaças da organização para que as ações de mitigação adequadas possam ser tomadas.

Orientação

Informações sobre ameaças existentes ou emergentes são coletadas e analisadas com objetivo de:

- a) facilitar ações informadas para evitar que as ameaças causem danos à organização;
- b) reduzir o impacto dessas ameaças.

A inteligência de ameaças pode ser dividida em três camadas, a serem consideradas:

a) inteligência estratégica de ameaças: troca de informações de alto nível sobre o cenário de ameaças em mudança (por exemplo, tipos de atacantes ou tipos de ataques);

b) inteligência tática de ameaças: informações sobre as metodologias dos atacantes, ferramentas e tecnologias envolvidas;

c) inteligência operacional de ameaças: detalhes sobre ataques específicos, incluindo indicadores técnicos.

5.8. SEGURANÇA DA INFORMAÇÃO NO GERENCIAMENTO DE PROJETOS

Controle

Convém que a segurança da informação seja integrada ao gerenciamento de projetos.

Propósito

Assegurar que os riscos de segurança da informação relacionados a projetos e entregas sejam efetivamente abordados no gerenciamento de projetos durante todo o ciclo de vida do projeto.

5.9. INVENTÁRIO DE INFORMAÇÕES E OUTROS ATIVOS ASSOCIADOS

Controle

Convém que um inventário de informações e outros ativos associados, incluindo proprietários, seja desenvolvido e mantido.

Propósito

Identificar as informações da organização e outros ativos associados, a fim de preservar a sua segurança da informação e atribuir a propriedade adequada.

5.10. USO ACEITÁVEL DE INFORMAÇÕES E OUTROS ATIVOS ASSOCIADOS**Controle**

Convém que regras para o uso aceitável e procedimentos para o manuseio de informações e outros ativos associados sejam identificados, documentados e implementados.

Propósito

Assegurar que as informações e outros ativos associados sejam devidamente protegidos, usados e manuseados.

5.11. DEVOLUÇÃO DE ATIVOS**Controle**

Convém que o pessoal e outras partes interessadas, conforme apropriado, devolvam todos os ativos da organização em sua posse após a mudança ou encerramento da contratação ou acordo.

Propósito

os ativos da organização como parte do processo de mudança ou encerramento da contratação ou acordo.

5.12. CLASSIFICAÇÃO DAS INFORMAÇÕES**Controle**

Convém que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização com base na confidencialidade, integridade, disponibilidade e requisitos relevantes das partes interessadas.

Propósito

Assegurar a identificação e o entendimento das necessidades de proteção das informações de acordo com a sua importância para a organização.

5.13. ROTULAGEM DE INFORMAÇÕES**Controle**

Convém que um conjunto adequado de procedimentos para rotulagem de informações seja desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.

Propósito

Facilitar a comunicação da classificação das informações e apoio à automação da gestão e tratamento das informações.

5.14. TRANSFERÊNCIA DE INFORMAÇÕES**Controle**

Convém que regras, procedimentos ou acordos de transferência de informações sejam implementados para todos os tipos de recursos de transferência dentro da organização e entre a organização e outras partes.

Propósito

Manter a segurança das informações transferidas dentro de uma organização e com qualquer parte interessada externa.

OrientaçãoGeral

Convém que a organização **estabeleça e comunique uma política específica por tema sobre transferência de informações** para todas as partes interessadas pertinentes.

Convém que regras, procedimentos e acordos para proteger informações em trânsito refitam a classificação das informações envolvidas.

Convém que quando as informações forem transferidas entre a organização e terceiros, os acordos de transferência (incluindo a autenticação do destinatário) sejam estabelecidos e mantidos para proteger as informações em todas as formas em trânsito.

A **transferência de informações** pode acontecer por:

- transferência eletrônica,
- transferência de mídia de armazenamento físico, e
- transferência verbal.

Convém que **para TODOS os tipos de transferência de informações, regras, procedimentos e acordos incluam:**

a) **controles projetados para proteger informações** transferidas contra interceptação, acesso não autorizado, cópia, modificação, desvio, destruição e negação de serviço, incluindo níveis de controle de acesso proporcionais à **classificação das informações** envolvidas e quaisquer **controles especiais necessários para proteger informações sensíveis**, [como o uso de técnicas criptográficas](#);

b) **controles para assegurar a rastreabilidade e não repúdio**, incluindo a manutenção de uma cadeia de custódia de informações durante o trânsito;

c) **identificação de contatos apropriados relacionados à transferência**, incluindo proprietários de informações, proprietários de riscos, agentes de segurança e custodiantes de informações, conforme aplicável;

- d) **responsabilidades**, incluindo responsabilidade cível em caso de incidentes de segurança da informação, como perda de mídia de armazenamento físico ou dados;
- e) **uso de um sistema de rotulagem acordado para informações sensíveis ou críticas**, assegurando que o significado dos rótulos seja imediatamente compreendido e que as informações sejam adequadamente protegidas;
- f) **confiabilidade e disponibilidade do serviço de transferência**;
- g) **política específica por tema** ou diretrizes sobre o uso aceitável de recursos de transferência de informações;
- h) **diretrizes de retenção e descarte** para todos os registros de negócios, incluindo mensagens;

DIRETO DO CONCURSO

002. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023)

Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

No desenvolvimento de uma política para criptografia, o uso de criptografia no transporte de mídias móveis é opcional, desde que, para o transporte, as mídias sejam lacradas e rastreadas durante todo o tempo em que estiverem em trânsito.



Veja o que a norma destaca:

Convém que **para TODOS os tipos de transferência de informações**, regras, procedimentos e acordos incluam:

a) **controles projetados para proteger informações** transferidas contra interceptação, acesso não autorizado, cópia, modificação, desvio, destruição e negação de serviço, incluindo níveis de controle de acesso proporcionais à **classificação das informações** envolvidas e **quaisquer controles especiais necessários para proteger informações sensíveis**, **como o uso de técnicas criptográficas**;

[...]

Com base na ABNT NBR ISO/IEC 27002:2022, a criptografia é uma medida de segurança essencial para proteger dados sensíveis, especialmente durante o transporte de mídias móveis. A norma enfatiza a importância de proteger a confidencialidade, integridade e disponibilidade das informações.

No contexto específico da criptografia para mídias móveis, a norma geralmente recomenda o uso de criptografia como uma prática padrão para garantir a segurança das informações, independentemente de outras medidas de segurança, como lacrar e rastrear as mídias.

Essas medidas adicionais são importantes e podem complementar o uso de criptografia, mas não substituem a necessidade de criptografar os dados.

Portanto, afirmar que o uso de criptografia no transporte de mídias móveis é opcional, desde que as mídias sejam lacradas e rastreadas, **não** está alinhado com as melhores práticas recomendadas pela norma. **A criptografia deve ser aplicada sempre que possível para garantir a proteção adequada das informações durante o transporte.**

Errado.

5.15. CONTROLE DE ACESSO

Controle

Convém que as regras para controlar o acesso físico e lógico às informações e outros ativos associados sejam estabelecidas e implementadas com base nos requisitos de segurança da informação e de negócios.

Propósito

Assegurar o acesso autorizado e evitar o acesso não autorizado a informações e outros ativos associados.

5.16. GESTÃO DE IDENTIDADE

Controle

Convém que o ciclo de vida completo das identidades seja gerenciado.

Propósito

Permitir a identificação única de indivíduos e sistemas que acessam as informações da organização e outros ativos associados e para permitir a cessão adequada de direitos de acesso.

5.17. INFORMAÇÕES DE AUTENTICAÇÃO

Controle

Convém que a alocação e a gestão de informações de autenticação sejam controladas por uma gestão de processo, incluindo aconselhar o pessoal sobre o manuseio adequado de informações de autenticação.

Propósito

Assegurar a autenticação adequada da entidade e evitar falhas nos processos de autenticação.

5.18. DIREITOS DE ACESSO

Controle

Convém que os direitos de acesso às informações e outros ativos associados sejam provisionados, analisados criticamente, modificados e removidos de acordo com a política de tema específico e regras da organização para o controle de acesso.

Propósito

Assegurar que o acesso às informações e outros ativos associados esteja definido e autorizado de acordo com os requisitos do negócio.

5.19. SEGURANÇA DA INFORMAÇÃO NAS RELAÇÕES COM FORNECEDORES

Controle

Convém que processos e procedimentos sejam definidos e implementados para gerenciar a segurança da informação e os riscos associados com o uso dos produtos ou serviços dos fornecedores.

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.20. ABORDAGEM DA SEGURANÇA DA INFORMAÇÃO NOS CONTRATOS DE FORNECEDORES

Controle

Convém que requisitos relevantes de segurança da informação sejam estabelecidos e acordados com cada fornecedor com base no tipo de relacionamento com o fornecedor.

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.21. GESTÃO DA SEGURANÇA DA INFORMAÇÃO NA CADEIA DE FORNECIMENTO DE TIC

Controle

Convém que processos e procedimentos sejam definidos e implementados para gerenciar riscos de segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.22. MONITORAMENTO, ANÁLISE CRÍTICA E GESTÃO DE MUDANÇAS DOS SERVIÇOS DE FORNECEDORES

Controle

Convém que a organização monitore, analise criticamente, avalie e gerencie regularmente a mudança nas práticas de segurança da informação dos fornecedores e na prestação de serviços.

Propósito

Manter um nível acordado de segurança da informação e prestação de serviços em linha com os acordos com os fornecedores.

5.23. SEGURANÇA DA INFORMAÇÃO PARA USO DE SERVIÇOS EM NUVEM

Controle

Convém que os processos de aquisição, uso, gestão e saída de serviços em nuvem sejam estabelecidos de acordo com os requisitos de segurança da informação da organização.

Propósito

Especificar e gerenciar a segurança da informação para o uso de serviços em nuvem.

5.24. PLANEJAMENTO E PREPARAÇÃO DA GESTÃO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que a organização planeje e se prepare para gerenciar incidentes de segurança da informação definindo, estabelecendo e comunicando processos, papéis e responsabilidades de gestão de incidentes de segurança da informação.

Propósito

Assegurar uma resposta rápida, eficaz, consistente e ordenada aos incidentes de segurança da informação, incluindo a comunicação sobre eventos de segurança da informação.

5.25. AVALIAÇÃO E DECISÃO SOBRE EVENTOS DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que a organização avalie os eventos de segurança da informação e decida se categoriza como incidentes de segurança da informação.

Propósito

Assegurar a efetiva categorização e priorização de eventos de segurança da informação.

5.26. RESPOSTA A INCIDENTES DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que os incidentes de segurança da informação sejam respondidos de acordo com os procedimentos documentados.

Propósito

Assegurar uma resposta eficiente e eficaz aos incidentes de segurança da informação.

5.27. APRENDIZADO COM INCIDENTES DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que o conhecimento adquirido com incidentes de segurança da informação seja usado para fortalecer e melhorar os controles de segurança da informação.

Propósito

Reduzir a probabilidade ou as consequências de futuros incidentes.

5.28. COLETA DE EVIDÊNCIAS

Controle

Convém que a organização estabeleça e implemente procedimentos para identificação, coleta, aquisição e preservação de evidências relacionadas a eventos de segurança da informação.

Propósito

Assegurar uma gestão consistente e eficaz das evidências relacionadas a incidentes de segurança da informação para fins de ações disciplinares e legais.

5.29. SEGURANÇA DA INFORMAÇÃO DURANTE A DISRUPÇÃO

Controle

Convém que a organização planeje como manter a segurança da informação em um nível apropriado durante a disrupção.

Propósito

Proteger as informações e outros ativos associados durante a disrupção.

5.30. PRONTIDÃO DE TIC PARA CONTINUIDADE DE NEGÓCIOS

Controle

Convém que a prontidão da TIC seja planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade da TIC.

Propósito

Assegurar a disponibilidade das informações da organização e outros ativos associados durante a interrupção.

5.31. REQUISITOS LEGAIS, ESTATUTÁRIOS, REGULAMENTARES E CONTRATUAIS**Controle**

Convém que os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e à abordagem da organização para atender a esses requisitos sejam identificados, documentados e atualizados.

Propósito

Assegurar o *compliance* dos requisitos legais, estatutários, regulamentares e contratuais relacionados à segurança da informação.

5.32. DIREITOS DE PROPRIEDADE INTELECTUAL**Controle**

Convém que a organização implemente procedimentos adequados para proteger os direitos de propriedade intelectual.

Propósito

Assegurar o *compliance* dos requisitos legais, estatutários, regulamentares e contratuais relacionados aos direitos de propriedade intelectual e ao uso de produtos proprietários.

5.33. PROTEÇÃO DE REGISTROS**Controle**

Convém que os registros sejam protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.

Propósito

Assegurar o *compliance* dos requisitos legais, estatutários, regulamentares e contratuais, bem como expectativas comunitárias ou sociais relacionadas à proteção e disponibilidade de registros.

5.34. PRIVACIDADE E PROTEÇÃO DE DP**Controle**

Convém que a organização identifique e atenda aos requisitos relativos à preservação da privacidade e proteção de DP de acordo com as leis e regulamentos aplicáveis e requisitos contratuais.

Propósito

Assegurar o *compliance* dos requisitos legais, estatutários, regulamentares e contratuais relacionados aos aspectos de segurança da informação da proteção de DP.

5.35. ANÁLISE CRÍTICA INDEPENDENTE DA SEGURANÇA DA INFORMAÇÃO**Controle**

Convém que a abordagem da organização para gerenciar a segurança da informação e sua implementação, incluindo pessoas, processos e tecnologias, seja analisada criticamente de forma independente a intervalos planejados ou quando ocorrem mudanças significativas.

Propósito

Assegurar a contínua adequação, suficiência e eficácia da abordagem da organização para a gestão da segurança da informação.

5.36. CONFORMIDADE COM POLÍTICAS, REGRAS E NORMAS PARA SEGURANÇA DA INFORMAÇÃO**Controle**

Convém que o *compliance* da política de segurança da informação da organização, políticas, regras e normas de temas específicos seja analisado criticamente a intervalos regulares.

Propósito

Assegurar que a segurança da informação seja implementada e operada de acordo com a política de segurança da informação da organização, políticas, regras e normas específicas por tema.

5.37. DOCUMENTAÇÃO DOS PROCEDIMENTOS DE OPERAÇÃO**Controle**

Convém que os procedimentos de operação dos recursos de tratamento da informação sejam documentados e disponibilizados para o pessoal que necessite deles.

Propósito

Assegurar a operação correta e segura dos recursos de tratamento da informação.

6. CONTROLES DE PESSOAS**6.1. SELEÇÃO****Controle**

Convém que verificações de antecedentes de todos os candidatos a serem contratados sejam realizadas antes de ingressarem na organização e de modo contínuo, de acordo com

as leis, regulamentos e ética aplicáveis e que sejam proporcionais aos requisitos do negócio, à classificação das informações a serem acessadas e aos riscos percebidos.

Propósito

Assegurar que todo o pessoal seja elegível e adequado para os papéis para os quais são considerados e permaneça elegível e adequado durante sua contratação.

6.2. TERMOS E CONDIÇÕES DE CONTRATAÇÃO

Controle

Convém que os contratos trabalhistas declarem as responsabilidades do pessoal e da organização para a segurança da informação.

Propósito

Assegurar que o pessoal entenda suas responsabilidades de segurança da informação para os papéis para os quais eles são considerados.

6.3. CONSCIENTIZAÇÃO, EDUCAÇÃO E TREINAMENTO EM SEGURANÇA DA INFORMAÇÃO

Controle

Convém que o pessoal da organização e partes interessadas relevantes recebam treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas e procedimentos específicas por tema, pertinentes para as suas funções.

Propósito

Assegurar que o pessoal e as partes interessadas pertinentes estejam cientes e cumpram suas responsabilidades de segurança da informação.

6.4. PROCESSO DISCIPLINAR

Controle

Convém que um processo disciplinar seja formalizado e comunicado, para tomar ações contra pessoal e outras partes interessadas relevantes que tenham cometido uma violação da política de segurança da informação.

Propósito

Assegurar que o pessoal e outras partes interessadas pertinentes entendam as consequências da violação da política de segurança da informação, para dissuadir e lidar adequadamente com as pessoas que cometeram a violação.

6.5. RESPONSABILIDADES APÓS ENCERRAMENTO OU MUDANÇA DA CONTRATAÇÃO

Controle

Convém que as responsabilidades e funções de segurança da informação que permaneçam válidos após o encerramento ou mudança da contratação sejam definidos, aplicados e comunicados ao pessoal e outras partes interessadas pertinentes.

Propósito

Proteger os interesses da organização como parte do processo de mudança ou encerramento da contratação ou de um contrato.

6.6. ACORDOS DE CONFIDENCIALIDADE OU NÃO DIVULGAÇÃO

Controle

Convém que acordos de confidencialidade ou não divulgação que refitam as necessidades da organização para a proteção das informações sejam identificados, documentados, analisados criticamente em intervalos regulares e assinados por pessoal e outras partes interessadas pertinentes.

Propósito

Manter a confidencialidade das informações acessíveis pelo pessoal ou por partes externas.

6.7. TRABALHO REMOTO

Controle

Convém que medidas de segurança sejam implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.

Propósito

Assegurar a segurança das informações quando o pessoal estiver trabalhando remotamente.

6.8. RELATO DE EVENTOS DE SEGURANÇA DA INFORMAÇÃO

Controle

Convém que a organização forneça um mecanismo para que as pessoas relatem eventos de segurança da informação observados ou suspeitos por meio de canais apropriados em tempo hábil.

Propósito

Oferecer apoio em tempo hábil a relatos, consistentes e eficazes de eventos de segurança da informação que podem ser identificados pelo pessoal.

7. CONTROLES FÍSICOS

7.1. PERÍMETROS DE SEGURANÇA FÍSICA

Controle

Convém que perímetros de segurança sejam definidos e usados para proteger áreas que contenham informações e outros ativos associados.

Propósito

Evitar acesso físico não autorizado, danos e interferências nas informações da organização e outros ativos associados.

7.2. ENTRADA FÍSICA

Controle

Convém que as áreas seguras sejam protegidas por controles de entrada e pontos de acesso apropriados.

Propósito

Assegurar que ocorra apenas acesso físico autorizado às informações da organização e outros ativos associados.

7.3. SEGURANÇA DE ESCRITÓRIOS, SALAS E INSTALAÇÕES

Controle

Convém que seja projetada e implementada segurança física para escritórios, salas e instalações

Propósito

Evitar acesso físico não autorizado, danos e interferências nas informações da organização e outros ativos associados em escritórios, salas e instalações.

7.4. MONITORAMENTO DE SEGURANÇA FÍSICA

Controle

Convém que as instalações sejam monitoradas continuamente para acesso físico não autorizado.

Propósito

Detectar e impedir o acesso físico não autorizado.

7.5. PROTEÇÃO CONTRA AMEAÇAS FÍSICAS E AMBIENTAIS

Controle

Convém que a proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, seja projetada e implementada.

Propósito

Prevenir ou reduzir as consequências de eventos originários de ameaças físicas e ambientais.

7.6. TRABALHO EM ÁREAS SEGURAS

Controle

Convém que medidas de segurança para trabalhar em áreas seguras sejam projetadas e implementadas.

Propósito

Proteger as informações e outros ativos associados em áreas seguras contra danos e interferência não autorizada do pessoal que trabalha nessas áreas.

7.7. MESA LIMPA E TELA LIMPA

Controle

Convém que regras de mesa limpa para documentos impressos e mídia de armazenamento removível e regras de tela limpa para os recursos de tratamento das informações sejam definidas e adequadamente aplicadas.

Propósito

Reduzir os riscos de acesso não autorizado, perda e danos às informações em mesas, telas e em outros locais acessíveis durante e fora do horário comercial.

7.8. LOCALIZAÇÃO E PROTEÇÃO DE EQUIPAMENTOS

Controle

Convém que os equipamentos sejam posicionados com segurança e proteção.

Propósito

Reduzir os riscos de ameaças físicas e ambientais, e de acesso não autorizado e danos.

7.9. SEGURANÇA DE ATIVOS FORA DAS INSTALAÇÕES DA ORGANIZAÇÃO

Controle

Convém proteger os ativos fora das instalações da organização.

Propósito

Evitar perdas, danos, roubos ou comprometimento de ativos fora das instalações da organização e interrupção da operação da organização.

7.10. MÍDIA DE ARMAZENAMENTO**Controle**

Convém que as mídias de armazenamento sejam gerenciadas por seu ciclo de vida de aquisição, uso, transporte e descarte, de acordo com o esquema de classificação e com os requisitos de manuseio da organização.

Propósito

Assegurar a divulgação, modificação, remoção ou destruição de informações apenas de forma autorizada sobre as mídias de armazenamento.

7.11. SERVIÇOS DE INFRAESTRUTURA**Controle**

Convém que as instalações de tratamento de informações sejam protegidas contra falhas de energia e outras disrupções causadas por falhas nos serviços de infraestrutura.

Propósito

Evitar perdas, danos ou comprometimento de informações e outros ativos associados, ou a interrupção das operações da organização devido à falha e disrupção nos serviços de infraestrutura.

7.12. SEGURANÇA DO CABEAMENTO**Controle**

Convém que os cabos que transportam energia ou dados ou que sustentam serviços de informação sejam protegidos contra interceptação, interferência ou danos.

Propósito

Evitar perdas, danos, roubo ou comprometimento de informações e outros ativos associados à interrupção das operações da organização relacionadas ao cabeamento de energia e de comunicação.

7.13. MANUTENÇÃO DE EQUIPAMENTOS**Controle**

Convém que os equipamentos sejam mantidos corretamente para assegurar a disponibilidade, integridade e confidencialidade da informação.

Propósito

Evitar perdas, danos, roubos ou comprometimento de informações e outros ativos associados e interrupção das operações da organização causada pela falta de manutenção.

7.14. DESCARTE SEGURO OU REUTILIZAÇÃO DE EQUIPAMENTOS

Controle

Convém que sejam verificados os itens dos equipamentos que contenham mídia de armazenamento, para assegurar que quaisquer dados confidenciais e software licenciado tenham sido removidos ou substituídos com segurança antes do descarte ou reutilização.

Propósito

Evitar o vazamento de informações por equipamento que seja descartado ou reutilizado.

8. CONTROLES TECNOLÓGICOS

8.1. DISPOSITIVOS *ENDPOINT* DO USUÁRIO

Controle

Convém que as informações armazenadas, tratadas ou acessíveis por meio de dispositivos endpoint do usuário sejam protegidas.

Propósito

Proteger informações contra os riscos introduzidos pelo uso de dispositivos endpoint do usuário.

8.2. DIREITOS DE ACESSOS PRIVILEGIADOS

Tipo de controle	Propriedades de segurança da informação	Conceitos de segurança cibernética	Capacidades operacionais	Domínios de segurança
#Preventivo	#Confidencialidade #Integridade #Disponibilidade	#Proteger	#Gestão_de_identidade_e_acesso	#Proteção

Controle

Convém **restringir e gerenciar a atribuição e o uso de direitos de acessos privilegiados**.

Propósito

Assegurar que apenas usuários, componentes de software e serviços autorizados recebam direitos de acessos privilegiados.

Orientação

Convém que a **atribuição de direitos de acesso privilegiado seja controlada** por meio de um processo de autorização de acordo com a política específica por tema de controle de acessos. Convém considerar:

a) **identificar usuários que precisem de direitos de acesso privilegiados** para cada sistema ou processo (Ex.: sistemas operacionais, sistemas de gerenciamento de banco de dados e aplicações);

b) **atribuir direitos de acesso privilegiado aos usuários conforme necessário** e em um princípio de evento por evento, em consonância com a política específica por tema de controle de acesso (ou seja, apenas para indivíduos com a competência necessária para realizar atividades que exijam acesso privilegiado e com base no requisito mínimo para seus papéis funcionais);

c) manter um processo de autorização (ou seja, determinar quem pode aprovar direitos de acesso privilegiado, ou não conceder direitos de acesso privilegiado até que o processo de autorização seja concluído) e um registro de todos os privilégios alocados;

d) definir e **implementar requisitos para o término dos direitos de acesso privilegiado**;

e) tomar medidas para **assegurar que os usuários estejam cientes de seus direitos de acesso privilegiados** e quando estão no modo de acesso privilegiado. As medidas possíveis incluem o uso de identidades específicas do usuário, configurações de interface do usuário ou até mesmo equipamentos específicos;

f) os requisitos de autenticação para direitos de acesso privilegiados podem ser maiores do que os requisitos para os direitos normais de acesso;

g) regularmente, e após qualquer mudança organizacional, analisar criticamente os usuários trabalhando com direitos de acesso privilegiados, a fim de verificar se suas funções, papéis, responsabilidades e competências ainda os qualificam para trabalhar com direitos de acesso privilegiados;

h) **estabelecer regras específicas para evitar o uso de ID genéricos de usuário de administração** (como “root”), dependendo dos recursos de configuração dos sistemas. Gerenciar e proteger informações de autenticação destas identidades;

i) conceder acesso privilegiado **temporário** apenas pelo período necessário para implementar alterações ou atividades aprovadas, **em vez de conceder permanentemente direitos de acesso privilegiado**;

j) **registrar todo o acesso privilegiado** ao sistema para fins de auditoria;

k) não compartilhar ou vincular identidades com direitos de acesso privilegiados a várias pessoas, atribuindo a cada pessoa uma identidade separada que permita atribuir direitos específicos de acesso privilegiado;

l) usar identidades com direitos de acesso privilegiados apenas para a realização de tarefas administrativas e não para tarefas gerais do dia a dia.

8.3. RESTRIÇÃO DE ACESSO À INFORMAÇÃO

Controle

Convém que o acesso às informações e outros ativos associados seja restrito de acordo com a política específica por tema sobre controle de acesso.

Propósito

Assegurar apenas o acesso autorizado e impedir o acesso não autorizado a informações e a outros ativos associados.

8.4. ACESSO AO CÓDIGO-FONTE

Controle

Convém que os acessos de leitura e escrita ao código-fonte, ferramentas de desenvolvimento e bibliotecas de software sejam adequadamente gerenciados.

Propósito

Evitar a introdução de funcionalidades não autorizadas, prevenir mudanças não intencionais ou maliciosas e manter a confidencialidade de propriedade intelectual valiosa.

8.5. AUTENTICAÇÃO SEGURA

Controle

Convém que sejam implementadas tecnologias e procedimentos de autenticação seguros, com base em restrições de acesso à informação e à política específica por tema de controle de acesso.

Propósito

Assegurar que um usuário ou uma entidade seja autenticada com segurança, quando o acesso a sistemas, aplicações e serviços é concedido.

8.6. GESTÃO DE CAPACIDADE

Controle

Convém que o uso dos recursos seja monitorado e ajustado de acordo com os requisitos atuais e esperados de capacidade.

Propósito

Assegurar a capacidade necessária dos recursos de tratamento de informações, recursos humanos, escritórios e outros serviços de infraestrutura.

8.7. PROTEÇÃO CONTRA MALWARE

Controle

Convém que a proteção contra malware seja implementada e apoiada pela conscientização adequada do usuário.

Propósito

Assegurar que informações e outros ativos associados estejam protegidos contra *malware*.

8.8. GESTÃO DE VULNERABILIDADES TÉCNICAS**Controle**

Convém que informações sobre vulnerabilidades técnicas dos sistemas de informação em uso sejam obtidas, a exposição da organização a tais vulnerabilidades sejam avaliadas e medidas apropriadas sejam tomadas.

Propósito

Evitar a exploração de vulnerabilidades técnicas

8.9. GESTÃO DE CONFIGURAÇÃO**Controle**

Convém que as configurações, incluindo configurações de segurança, de hardware, software, serviços e redes sejam estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente.

Propósito

Assegurar que o hardware, o software, os serviços e as redes funcionem corretamente com as configurações de segurança necessárias, e que a configuração não seja alterada por alterações não autorizadas ou incorretas.

8.10. EXCLUSÃO DE INFORMAÇÕES**Controle**

Convém que as informações armazenadas em sistemas de informação, dispositivos ou em qualquer outra mídia de armazenamento sejam excluídas quando não forem mais necessárias.

Propósito

Evitar a exposição desnecessária de informações sensíveis e estar em compliance com requisitos legais, estatutários, regulamentares e contratuais para a exclusão de informações.

8.11. MASCARAMENTO DE DADOS**Controle**

Convém que o mascaramento de dados seja usado de acordo com a política específica por tema da organização sobre controle de acesso e outros requisitos específicos por tema relacionados e requisitos de negócios, levando em consideração a legislação aplicável.

Propósito

Limitar a exposição de dados confidenciais, incluindo DP, e cumprir requisitos legais, estatutários, regulamentares e contratuais.

8.12. PREVENÇÃO DE VAZAMENTO DE DADOS**Controle**

Convém que medidas de prevenção de vazamento de dados sejam aplicadas a sistemas, redes e quaisquer outros dispositivos que tratem, armazenem ou transmitam informações sensíveis.

Propósito

Detectar e prevenir a divulgação e extração não autorizadas de informações por indivíduos ou sistemas.

8.13. BACKUP DAS INFORMAÇÕES**Controle**

Convém que cópias de *backup* de informações, *software* e sistemas sejam mantidas e testadas regularmente de acordo com a política específica por tema acordada sobre *backup*.

Propósito

Permitir a recuperação da perda de dados ou sistemas.

8.14. REDUNDÂNCIA DOS RECURSOS DE TRATAMENTO DE INFORMAÇÕES**Controle**

Convém que os recursos de tratamento de informações sejam implementados com redundância suficiente para atender aos requisitos de disponibilidade.

Propósito

Assegurar o funcionamento contínuo dos recursos de tratamento de informações.

8.15. LOG**Controle**

Convém que *logs* que registrem atividades, exceções, falhas e outros eventos relevantes sejam produzidos, armazenados, protegidos e analisados.

Propósito

Registrar eventos, gerar evidências, assegurar a integridade das informações de registro, prevenir contra acesso não autorizado, identificar eventos de segurança da informação que possam levar a um incidente de segurança da informação e apoiar investigações.

8.16. ATIVIDADES DE MONITORAMENTO

Controle

Convém que redes, sistemas e aplicações sejam monitorados por comportamentos anômalos e por ações apropriadas, tomadas para avaliar possíveis incidentes de segurança da informação.

Propósito

Detectar comportamentos anômalos e possíveis incidentes de segurança da informação.

8.17. SINCRONIZAÇÃO DO RELÓGIO

Controle

Convém que os relógios dos sistemas de tratamento de informações utilizados pela organização sejam sincronizados com fontes de tempo aprovadas.

Propósito

Permitir a correlação e a análise de eventos relacionadas à segurança e a outros dados registrados, e apoiar investigações sobre incidentes de segurança da informação.

8.18. USO DE PROGRAMAS UTILITÁRIOS PRIVILEGIADOS

Controle

Convém que o uso de programas utilitários que possam ser capazes de substituir os controles de sistema e aplicações seja restrito e rigorosamente controlado.

Propósito

Assegurar que o uso de programas utilitários não prejudique os controles do sistema e das aplicações para a segurança da informação.

8.19. INSTALAÇÃO DE SOFTWARE EM SISTEMAS OPERACIONAIS

Controle

Convém que procedimentos e medidas sejam implementados para gerenciar com segurança a instalação de software em sistemas operacionais.

Propósito

Assegurar a integridade dos sistemas operacionais e evitar a exploração de vulnerabilidades técnicas.

8.20. SEGURANÇA DE REDES

Controle

Convém que redes e dispositivos de rede sejam protegidos, gerenciados e controlados para proteger as informações em sistemas e aplicações.

Propósito

Proteger as informações nas redes e seus recursos de tratamento de informações de suporte contra o comprometimento por rede.

8.21. SEGURANÇA DOS SERVIÇOS DE REDE**Controle**

Convém que sejam identificados, implementados e monitorados mecanismos de segurança, níveis de serviço e requisitos de serviços de rede.

Propósito

Assegurar a segurança no uso de serviços de rede.

8.22. SEGREGAÇÃO DE REDES**Controle**

Convém que grupos de serviços de informação, usuários e sistemas de informação sejam segregados nas redes da organização.

Propósito

Dividir a rede em perímetros de segurança e controlar o tráfego entre eles com base nas necessidades de negócios.

8.23. FILTRAGEM DA WEB**Controle**

Convém que o acesso a sites externos seja gerenciado para reduzir a exposição a conteúdo malicioso.

Propósito

Proteger os sistemas de serem comprometidos por malware e impedir o acesso a recursos web não autorizados.

8.24. USO DE CRIPTOGRAFA**Controle**

Convém que sejam definidas e implementadas regras para o uso efetivo da criptografia, incluindo o gerenciamento de chaves criptográficas.

Propósito

Assegurar o uso adequado e eficaz da criptografia para proteger a confidencialidade, autenticidade ou integridade das informações de acordo com os requisitos de segurança das empresas e da informação, e levando em consideração os requisitos legais, estatutários, regulamentares e contratuais relacionados à criptografia.

8.25. CICLO DE VIDA DE DESENVOLVIMENTO SEGURO

Controle

Convém que regras para o desenvolvimento seguro de software e sistemas sejam estabelecidas e aplicadas.

Propósito

Assegurar que a segurança da informação seja projetada e implementada dentro do ciclo de vida de desenvolvimento seguro de software e sistemas.

8.26. REQUISITOS DE SEGURANÇA DA APLICAÇÃO

Controle

Convém que os requisitos de segurança da informação sejam identificados, especificados e aprovados ao desenvolver ou adquirir aplicações.

Propósito

Assegurar que todos os requisitos de segurança da informação sejam identificados e abordados ao desenvolver ou adquirir aplicações.

8.27. PRINCÍPIOS DE ARQUITETURA E ENGENHARIA DE SISTEMAS SEGUROS

Controle

Convém que princípios de engenharia para sistemas de segurança sejam estabelecidos, documentados, mantidos e aplicados a qualquer atividade de desenvolvimento de sistemas.

Propósito

Assegurar que os sistemas de informação sejam projetados, implementados e operados com segurança dentro do ciclo de vida de desenvolvimento.

8.28. CODIFICAÇÃO SEGURA

Controle

Convém que princípios de codificação segura sejam aplicados ao desenvolvimento de software.

Propósito

Assegurar que o software seja escrito com segurança, reduzindo assim o número de potenciais vulnerabilidades de segurança da informação no software.

8.29. TESTES DE SEGURANÇA EM DESENVOLVIMENTO E ACEITAÇÃO

Controle

Convém que os processos de teste de segurança sejam definidos e implementados no ciclo de vida do desenvolvimento.

Propósito

Validar se os requisitos de segurança da informação são atendidos quando as aplicações ou códigos são implantados no ambiente de produção.

8.30. DESENVOLVIMENTO TERCEIRIZADO**Controle**

Convém que a organização dirija, monitore e analise criticamente as atividades relacionadas à terceirização de desenvolvimento de sistemas.

Propósito

Assegurar que as medidas de segurança da informação requeridas pela organização sejam implementadas na terceirização do desenvolvimento de sistemas.

8.31. SEPARAÇÃO DOS AMBIENTES DE DESENVOLVIMENTO, TESTE E PRODUÇÃO**Controle**

Convém que ambientes de desenvolvimento, testes e produção sejam separados e protegidos.

Propósito

Proteger o ambiente de produção e os dados de comprometimento por meio de atividades de desenvolvimento e teste.

8.32. GESTÃO DE MUDANÇAS**Controle**

Convém que mudanças nos recursos de tratamento de informações e sistemas de informação estejam sujeitas a procedimentos de gestão de mudanças.

Propósito

Preservar a segurança da informação ao executar mudanças.

8.33. INFORMAÇÕES DE TESTE**Controle**

Convém que as informações de teste sejam adequadamente selecionadas, protegidas e gerenciadas.

Propósito

Assegurar a relevância dos testes e a proteção das informações operacionais utilizadas para testes.

8.34. PROTEÇÃO DE SISTEMAS DE INFORMAÇÃO DURANTE OS TESTES DE AUDITORIA

Controle

Convém que testes de auditoria e outras atividades de garantia envolvendo a avaliação de sistemas operacionais sejam planejados e acordados entre o testador e a gestão apropriada.

Propósito

Minimizar o impacto da auditoria e outras atividades de garantia em sistemas operacionais e processos de negócio.

RESUMO

ABNT NBR ISO/IEC 27002:2022 - Segurança da informação, segurança cibernética e proteção à privacidade — Controles de segurança da informação

- Esta norma serve como referência **para determinar e implementar controles para tratamento de riscos de segurança da informação em um sistema de gestão de segurança da informação (SGSI)** baseado na ABNT NBR ISO/IEC 27001.
- É uma ferramenta valiosa para organizações de **todos os tamanhos e setores**.
- As **principais seções** da norma ABNT NBR ISO IEC 27002:2022 são:

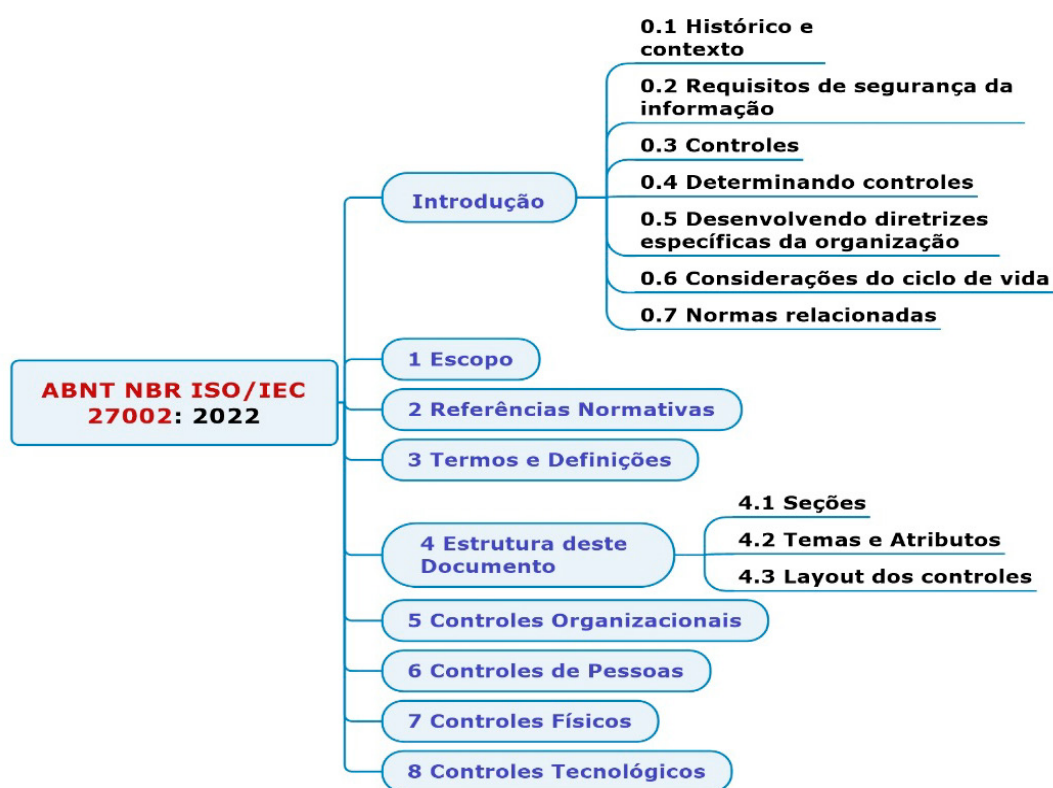


Figura. Seções da norma ABNT NBR ISO/IEC 27002 (QUINTÃO, 2024)

A norma está estruturada da seguinte forma:

- Controles organizacionais (Seção 5).
- Controles de pessoas (Seção 6).
- Controles físicos (Seção 7).
- Controles tecnológicos (Seção 8).

A categorização dos controles nas Seções 5 a 8 é referida como temas. Os controles são classificados como:

- pessoas, se eles dizem respeito a indivíduos;
- físico, se dizem respeito a objetos físicos;

- c) tecnológico, se relacionados à tecnologia.
- d) caso contrário, eles são categorizados como organizacionais.

A norma inclui dois anexos informativos:

- a) Anexo A

Uso de atributos: explica como uma organização pode utilizar atributos para criar visões personalizadas com base nos atributos de controle definidos no documento ou de sua própria criação.

Este Anexo fornece uma tabela para demonstrar o uso de atributos como forma de criar diferentes visões dos controles.

Os controles são **categorizados** como:

- a) pessoas, se eles dizem respeito a pessoas individuais;
- b) físico, se eles dizem respeito a objetos físicos;
- c) tecnológico, se eles dizem respeito à tecnologia;
- d) caso contrário, eles são categorizados como organizacionais

Tipos de controle

(#Preventivo, #Detectivo, #Corretivo)

Propriedades de segurança da informação

(#Confidencialidade, #Integridade, #Disponibilidade)

Conceitos de segurança cibernética

(#Identificar, #Proteger, #Detectar, #Responder, #Restaurar)

- b) Anexo B

Correspondência com a ABNT NBR ISO/IEC 27002:2013: apresenta a correspondência entre os controles desta edição e a edição anterior de 2013.

EXERCÍCIOS

001. (FGV/ANALISTA JUDICIÁRIO (TRF 1ª REGIÃO)/APOIO ESPECIALIZADO/GOVERNANÇA E GESTÃO DE TECNOLOGIA DA INFORMAÇÃO/2024) A Norma ABNT NBR ISO/IEC 27002:2022 orienta que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização.

De acordo com essa norma, na classificação da informação devem-se considerar os requisitos de:

- a) confiabilidade, integridade, disponibilidade e os que sejam relevantes para a alta gestão;
- b) confidencialidade, integridade, autenticidade e os que sejam relevantes para as partes interessadas;
- c) confiabilidade, integridade, autenticidade e os que sejam relevantes para as partes interessadas;
- d) confidencialidade, integridade, disponibilidade e os que sejam relevantes para as partes interessadas;
- e) confiabilidade, integridade, disponibilidade e os que sejam relevantes para a área de tecnologia da informação.

002. (CESGRANRIO/ANALISTA (BNDES)/ANÁLISE DE SISTEMA - CIBERSEGURANÇA/2024) A norma ABNT NBR ISO/IEC 27002:2022 organiza os controles de segurança em diferentes categorias (ou temas), e cada controle está associado a cinco atributos com valores de atributo correspondentes. Dentre esses atributos, o de domínios de segurança é usado para visualizar controles na perspectiva de quatro domínios de segurança da informação. Os valores desse atributo consistem em:

- a) Confidencialidade, Integridade, Disponibilidade e Resiliência
- b) Governança, Defesa, Continuidade e Segurança_física
- c) Governança, Confidencialidade, Integridade e Disponibilidade
- d) Governança_e_Ecossistema, Proteção, Defesa e Resiliência
- e) Governança_e_Ecossistema, Proteção, Defesa e Segurança_física

003. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Os direitos concedidos a usuários com acessos privilegiados são restritos e controlados, sendo necessário ter requisitos para expirar esse tipo de acesso.

004. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

No gerenciamento de informações, deve ser evitado o uso de mensagens de correio eletrônico de terceiros para o fornecimento de informações temporárias de autenticação secreta de usuários.

005. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

O controle de acesso a código-fonte de programas deve ser vedado à maioria dos times de tecnologia, exceto ao time de suporte, que deve ter acesso irrestrito às bibliotecas de programa-fonte.

006. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Em um perímetro de segurança física, as portas corta-fogo devem ser providas de alarme e monitoramentos e devem ser testadas em conjunto com as paredes, a fim de se estabelecer o nível de resistência exigido.

007. (CESPE/CGE – CE/AUDITOR DE CONTROLE INTERNO - TECNOLOGIA DA INFORMAÇÃO/2019/ADAPTADA) Em uma organização em que se processam dados pessoais sensíveis, existe a preocupação com o manuseio dos dados pelos empregados, para que não aconteçam vazamentos de dados e exposição indevida de pessoas. Segundo a NBR ISO/IEC 27002, para assegurar que as referidas informações pessoais recebam o nível adequado de proteção, deve-se utilizar como controle

- a) o descarte de mídias.
- b) o uso aceitável de ativos.
- c) o gerenciamento de chaves.
- d) o provisionamento para acesso de usuário.
- e) classificação das informações.

008. (CESPE/EBSERH/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2018/ADAPTADA) Julgue o próximo item, a respeito da segurança da informação.

De acordo com a norma ISO 27002:2022, é conveniente que, na política de segurança da informação, seja incluída atribuição de responsabilidades, gerais e específicas, para o gerenciamento da segurança da informação.

009. (CESPE/STJ/TÉCNICO JUDICIÁRIO/SUPORTE TÉCNICO/2018/ADAPTADA) Julgue o item seguinte, a respeito das disposições constantes da **NBR ISO/IEC 27002:2022**.

Os controles da segurança da informação elencados na NBR ISO/IEC 27002:2022 englobam as ações realizadas na gestão de projetos específicos da área de segurança da informação, as quais, porém, não lidam com controles que visem proteger a informação processada em sítios de teletrabalho.

010. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA - CONTROLE EXTERNO/2015) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002. A política de segurança deve ser aprovada pelo gestor máximo da instituição, assinada pelo chefe da informática, e divulgada para o pessoal de tecnologia da informação e comunicação (TIC).

011. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

Convém que seja projetada e implementada segurança física para escritórios, salas e instalações.

012. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Uma política de gerenciamento de chaves deve estabelecer a forma apropriada de lidar com chaves comprometidas: deve-se manter registro e auditoria das atividades que tenham relação com o gerenciamento de chaves e não se deve jamais destruir chaves comprometidas, as quais devem ser somente arquivadas.

013. (CESGRANRIO/TÉCNICO BANCÁRIO NOVO (CEF)/ADMINISTRATIVA/APLICAÇÃO RS/2024) A ABNT NBR ISO/IEC 27002:2022 fornece um conjunto de referência de controles genéricos de segurança da informação, incluindo orientação para implementação. Uma das definições presentes nessa norma se refere a um incidente, seja previsto ou imprevisto, que causa um desvio não planejado e negativo da expectativa de entrega de produtos e serviços de acordo com os objetivos da organização.

Essa é a definição de

- a) ataque
- b) ameaça
- c) interrupção
- d) vulnerabilidade
- e) violação de segurança da informação

014. (VUNESP/ANALISTA JUDICIÁRIO (TRF 3ª REGIÃO)/APOIO ESPECIALIZADO/INFORMÁTICA/2023) A norma ABNT NBR ISO/IEC 27002:2022 (Segurança da informação cibernética e proteção à privacidade – Controles de segurança da informação) estabelece, em seu capítulo 5, uma seção sobre inteligência de ameaças, na qual preconiza que tal tipo de inteligência seja dividido ou classificado em três camadas para tratamento de ameaças. Essas três camadas são as inteligências de ameaças

- a) interna, mista e externa.
- b) irrelevante, média e grave.
- c) de sistema, de invasão e de pessoas.
- d) preliminar, de objetivo e de finalização.
- e) estratégica, tática e operacional.

015. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 é aplicável apenas a grandes organizações, devido à complexidade dos controles de segurança da informação.

016. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 inclui controles específicos para a proteção de dados em trânsito e em repouso.

017. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

De acordo com a norma, a confidencialidade é o único princípio importante a ser considerado na classificação da informação.

018. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 recomenda que todos os controles de segurança sejam obrigatoriamente implementados em todas as organizações.

019. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A inteligência de ameaças, conforme descrita na norma, deve ser perspicaz e acionável.

020. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 organiza os controles em categorias como controles organizacionais, físicos, de pessoas e tecnológicos.

021. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma recomenda que a segurança da informação seja tratada exclusivamente como uma questão técnica, sem envolver a alta gestão.

022. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 sugere que a gestão de identidade e acesso é uma parte crítica da segurança da informação.

023. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma inclui diretrizes para a implementação de controles de segurança em ambientes de nuvem.

024. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

Os controles de segurança física são irrelevantes para a segurança da informação, segundo a norma.

025. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 não aborda a necessidade de conformidade com leis e regulamentos.

026. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma sugere que a análise de risco deve ser realizada apenas uma vez durante a implementação inicial de um sistema de segurança da informação.

027. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 inclui diretrizes para a resposta a incidentes de segurança da informação.

028. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma recomenda que todos os dados sejam criptografados, independentemente de seu valor ou sensibilidade.

029. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

De acordo com a norma, a segurança da informação deve ser integrada aos processos de negócios da organização.

GABARITO

1. d
2. d
3. C
4. C
5. E
6. C
7. e
8. C
9. E
10. E
11. C
12. E
13. c
14. e
15. E
16. C
17. E
18. E
19. C
20. C
21. E
22. C
23. C
24. E
25. E
26. E
27. C
28. E
29. C

GABARITO COMENTADO

001. (FGV/ANALISTA JUDICIÁRIO (TRF 1ª REGIÃO)/APOIO ESPECIALIZADO/GOVERNANÇA E GESTÃO DE TECNOLOGIA DA INFORMAÇÃO/2024) A Norma ABNT NBR ISO/IEC 27002:2022 orienta que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização.

De acordo com essa norma, na classificação da informação devem-se considerar os requisitos de:

- a) confiabilidade, integridade, disponibilidade e os que sejam relevantes para a alta gestão;
- b) confidencialidade, integridade, autenticidade e os que sejam relevantes para as partes interessadas;
- c) confiabilidade, integridade, autenticidade e os que sejam relevantes para as partes interessadas;
- d) confidencialidade, integridade, disponibilidade e os que sejam relevantes para as partes interessadas;
- e) confiabilidade, integridade, disponibilidade e os que sejam relevantes para a área de tecnologia da informação.



Veja o item **5.12 Classificação das informações:**

Controle

Convém que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização com base na confidencialidade, integridade, disponibilidade e requisitos relevantes das partes interessadas.

De acordo com a norma ABNT NBR ISO/IEC 27002:2022, na classificação da informação, devem-se considerar os requisitos de:

- d) confidencialidade, integridade, disponibilidade e os que sejam relevantes para as partes interessadas.

Esses três princípios — confidencialidade, integridade e disponibilidade — são fundamentais para a segurança da informação e são comumente referidos como a tríade CIA.

Eles garantem que as informações sejam acessadas apenas por pessoas autorizadas (confidencialidade), que os dados sejam precisos e completos (integridade), e que as informações estejam disponíveis quando necessárias (disponibilidade).

Além disso, considerar os requisitos relevantes para as partes interessadas assegura que as expectativas e necessidades específicas de segurança sejam atendidas.

Letra d.

002. (CESGRANRIO/ANALISTA (BNDES)/ANÁLISE DE SISTEMA - CIBERSEGURANÇA/2024) A norma ABNT NBR ISO/IEC 27002:2022 organiza os controles de segurança em diferentes categorias (ou temas), e cada controle está associado a cinco atributos com valores de atributo correspondentes. Dentre esses atributos, o de domínios de segurança é usado para visualizar controles na perspectiva de quatro domínios de segurança da informação. Os valores desse atributo consistem em:

- a) Confidencialidade, Integridade, Disponibilidade e Resiliência
- b) Governança, Defesa, Continuidade e Segurança_física
- c) Governança, Confidencialidade, Integridade e Disponibilidade
- d) Governança_e_Ecosistema, Proteção, Defesa e Resiliência
- e) Governança_e_Ecosistema, Proteção, Defesa e Segurança_física



Os **domínios de segurança** são um atributo para visualizar controles na perspectiva de quatro domínios de segurança da informação:

“Governança_e_Ecosistema” inclui “Governança do Sistema de Segurança da Informação e Gestão de Riscos” e “Gestão de segurança cibernética do ecossistema” (incluindo partes interessadas internas e externas);

“Proteção” inclui “Arquitetura de Segurança de TI”, “Administração de Segurança de TI”, “Gestão de identidade e acesso”, “Manutenção de Segurança de TI” e “Segurança física e ambiental”;

“Defesa” inclui “Detectar” e “Gestão de Incidente de segurança computacional”;

Resiliência inclui “Operações de continuidade” e “Gestão de crises”.

Assim, os valores de atributos consistem em Governança_e_Ecosistema, Proteção, Defesa e Resiliência.

Letra d.

003. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Os direitos concedidos a usuários com acessos privilegiados são restritos e controlados, sendo necessário ter requisitos para expirar esse tipo de acesso.



Direitos de acesso privilegiados são direitos de acesso fornecidos a uma identidade, um papel ou um processo, que permitem a realização de atividades que usuários ou processos típicos não estão aptos a realizar.

Os papéis de administrador do sistema normalmente exigem direitos de acesso privilegiados.

Com base na ABNT NBR ISO/IEC 27002:2022, é correto afirmar que **os direitos concedidos a usuários com acessos privilegiados devem ser restritos e controlados**. A norma enfatiza a importância de definir e implementar requisitos para o término dos direitos de acesso privilegiado. Isso inclui estabelecer um processo de autorização para aprovar ou não conceder tais direitos até que o processo de autorização seja concluído e garantir que esses direitos sejam removidos quando não forem mais necessários. Portanto, a afirmação está correta.
Certo.

004. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

No gerenciamento de informações, deve ser evitado o uso de mensagens de correio eletrônico de terceiros para o fornecimento de informações temporárias de autenticação secreta de usuários.



Conforme 5.14 da ABNT NBR ISO/IEC 27002:2022:

Transferência eletrônica

[...] f) restrições associadas com os recursos de comunicação eletrônica (por exemplo, prevenindo encaminhamento automático de correio eletrônico para endereços de correio externos);

Certo.

005. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

O controle de acesso a código-fonte de programas deve ser vedado à maioria dos times de tecnologia, exceto ao time de suporte, que deve ter acesso irrestrito às bibliotecas de programa-fonte.



O controle de acesso a código-fonte **não** deve ser estritamente controlado. Deve haver também um controle às bibliotecas de programa-fonte, já que é uma questão bastante sensível para o sucesso da operação.

A orientação da norma é a seguinte em 8.4 Acesso ao código-fonte:

“Convém que o acesso ao código-fonte e aos itens associados (como projetos, especificações, planos de verificação e planos de validação) e ferramentas de desenvolvimento (por exemplo,

compiladores, construtores, ferramentas de integração, plataformas de teste e ambientes) seja estritamente controlado. Para o código-fonte, isso pode ser alcançado controlando o armazenamento central de tal código, de preferência no sistema de gerenciamento de código-fonte. **Acesso de leitura e acesso de escrita ao código-fonte podem diferir com base no papel do pessoal.** Por exemplo, o acesso de leitura ao código-fonte pode ser amplamente fornecido dentro da organização, mas o acesso à gravação ao código-fonte só é disponibilizado para pessoas privilegiadas ou proprietários designados. **Quando os componentes de código são usados por vários desenvolvedores dentro de uma organização, convém que um acesso de leitura a um repositório centralizado de código seja implementado.** Além disso, se o código-fonte aberto ou componentes de código de terceiros forem usados dentro de uma organização, o acesso de leitura a esses repositórios de código externo pode ser amplamente fornecido. No entanto, convém que o acesso de gravação ainda seja restrito.

Errado.

006. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Em um perímetro de segurança física, as portas corta-fogo devem ser providas de alarme e monitoramentos e devem ser testadas em conjunto com as paredes, a fim de se estabelecer o nível de resistência exigido.



Com base na ABNT NBR ISO/IEC 27002:2022, o item está correto. A norma especifica que, dentro de um perímetro de segurança física, as portas de incêndio devem ser equipadas com alarmes e monitoramento. Além disso, é necessário realizar testes das portas em conjunto com as paredes para assegurar o nível de resistência exigido, conforme padrões adequados. A operação desses sistemas deve ser à prova de falhas, garantindo assim a segurança e a integridade do perímetro físico.

Vejamos abaixo essa descrição na Norma ABNT NBR ISO/IEC 27002:2022:

7 Controles físicos

7.1 Perímetros de segurança física

c) alarmar, monitorar e testar todas as portas de incêndio do perímetro de segurança, em conjunto com as paredes, para estabelecer o nível de resistência requerido, de acordo com as normas adequadas. Convém que eles operem no modo à prova de falhas

Fonte: ISO 27002/2022, página 83

Certo.

007. (CESPE/CGE – CE/AUDITOR DE CONTROLE INTERNO – TECNOLOGIA DA INFORMAÇÃO/2019/ADAPTADA) Em uma organização em que se processam dados pessoais sensíveis, existe a preocupação com o manuseio dos dados pelos empregados, para que não aconteçam vazamentos de dados e exposição indevida de pessoas. Segundo a NBR ISO/IEC 27002, para assegurar que as referidas informações pessoais recebam o nível adequado de proteção, deve-se utilizar como controle

- a) o descarte de mídias.
- b) o uso aceitável de ativos.
- c) o gerenciamento de chaves.
- d) o provisionamento para acesso de usuário.
- e) classificação das informações.



Para assegurar que a informação receba um nível adequado de proteção, de acordo com a sua importância para a organização, o controle a ser utilizado é o Classificação das Informações, que faz parte do domínio Controles Organizacionais.

Veja o que destaca o controle 5.12 Classificação das informações:

Convém que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização com base na confidencialidade, integridade, disponibilidade e requisitos relevantes das partes interessadas.

Letra e.

008. (CESPE/EBSERH/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2018/ADAPTADA) Julgue o próximo item, a respeito da segurança da informação.

De acordo com a norma ISO 27002:2022, é conveniente que, na política de segurança da informação, seja incluída atribuição de responsabilidades, gerais e específicas, para o gerenciamento da segurança da informação.



Quanto à orientação do controle organizacional **5.1 Políticas de segurança da informação**, convém que a **política de segurança da informação contenha declarações relativas** a:

- a) definição de segurança da informação;
- b) objetivos de segurança da informação ou a estrutura para definir objetivos de segurança da informação;
- c) princípios para orientar todas as atividades relacionadas à segurança da informação;
- d) comprometimento de satisfazer os requisitos aplicáveis relacionados à segurança da informação;

- e) comprometimento com a melhoria contínua do sistema de gestão da segurança da informação;
- f) **atribuição de responsabilidades para a gestão da segurança da informação para funções definidas;**
- g) procedimentos para tratamento de isenções e exceções.

Certo.

009. (CESPE/STJ/TÉCNICO JUDICIÁRIO/SUPORTE TÉCNICO/2018/ADAPTADA) Julgue o item seguinte, a respeito das disposições constantes da **NBR ISO/IEC 27002:2022**.

Os controles da segurança da informação elencados na NBR ISO/IEC 27002:2022 englobam as ações realizadas na gestão de projetos específicos da área de segurança da informação, as quais, porém, não lidam com controles que visem proteger a informação processada em sítios de teletrabalho.



O uso do Teletrabalho (ou **trabalho remoto**) está contemplado no item “**6.7. Trabalho remoto**”, da norma **NBR ISO/IEC 27002:2022**. Vamos ao que está explicitado na referida norma:

6.7. Trabalho remoto

Controle

Convém que medidas de segurança sejam implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.

Propósito

Assegurar a segurança das informações quando o pessoal estiver trabalhando remotamente.

Errado.

010. (CESPE/TCE-RN/ASSESSOR TÉCNICO DE INFORMÁTICA - CONTROLE EXTERNO/2015) Julgue os itens a seguir, acerca de gestão de segurança da informação à luz das normas ISO/IEC 27001 e 27002. A política de segurança deve ser aprovada pelo gestor máximo da instituição, assinada pelo chefe da informática, e divulgada para o pessoal de tecnologia da informação e comunicação (TIC).



A política de segurança deve ser definida no mais **alto nível da organização e aprovada pela direção**, sendo comunicada aos funcionários e partes externas relevantes de forma que seja entendida, acessível e relevante aos usuários pertinentes.

Errado.

011. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

Convém que seja projetada e implementada segurança física para escritórios, salas e instalações.



De acordo com **7.3 Segurança de escritórios, salas e instalações**, convém que seja projetada e implementada segurança física para escritórios, salas e instalações. **Propósito:** evitar acesso físico não autorizado, danos e interferências nas informações da organização e outros ativos associados em escritórios, salas e instalações.

Certo.

012. (CEBRASPE (CESPE)/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO (DATAPREV)/DESENVOLVIMENTO DE SOFTWARE/2023) Com base na ABNT NBR ISO/IEC 27002:2022, julgue o item a seguir.

Uma política de gerenciamento de chaves deve estabelecer a forma apropriada de lidar com chaves comprometidas: deve-se manter registro e auditoria das atividades que tenham relação com o gerenciamento de chaves e não se deve jamais destruir chaves comprometidas, as quais devem ser somente arquivadas.



Vejam as orientações para gerenciamento de chaves, destacadas na ABNT NBR ISO/IEC 27002:2022 em **8.24 Uso de criptografia**:

O gerenciamento adequado de chaves **requer processos seguros** para **gerar, armazenar, arquivar, recuperar, distribuir, retirar e destruir chaves criptográficas**.

Convém que um sistema de gerenciamento de chaves seja baseado em um conjunto acordado de padrões, procedimentos e métodos seguros para:

- a) **gerar** chaves para diferentes sistemas criptográficos e diferentes aplicações;
- b) **emitir e obter certificados** de chave pública;
- c) distribuir chaves para entidades pretendidas, incluindo como ativar chaves quando recebidas;
- d) armazenar chaves, incluindo como os usuários autorizados obtêm acesso às chaves;
- e) alterar ou atualizar chaves, incluindo regras sobre quando alterar chaves e como isso será feito;
- f) lidar com chaves comprometidas;
- g) **revogar chaves, incluindo como retirar ou desativar chaves** [por exemplo, **quando as chaves foram comprometidas** ou quando um usuário deixar uma organização (nesse caso, convém que as chaves também sejam arquivadas)];
- h) recuperar chaves que são perdidas ou corrompidas;
- i) backup ou arquivamento de chaves;

- j) destruir chaves;
- k) registrar e auditar as principais atividades relacionadas à gestão;
- l) definir datas de ativação e desativação para chaves, para que as chaves só possam ser usadas pelo período de tempo estabelecido conforme as regras da organização sobre gerenciamento de chaves;
- m) lidar com pedidos legais de acesso a chaves criptográficas (por exemplo, informações criptografadas podem ser necessárias para serem disponibilizadas de forma não criptografada como evidência em um processo judicial).

Convém que todas as chaves criptográficas sejam protegidas contra modificações e perdas. Além disso, chaves secretas e privadas precisam de proteção contra uso não autorizado, bem como divulgação.

Convém que os equipamentos usados para gerar, armazenar e arquivar chaves sejam protegidos fisicamente.

Além da integridade, convém, para muitos casos de uso, que a **autenticidade das chaves públicas também seja considerada.**

O item apresentado está incorreto de acordo com a ABNT NBR ISO/IEC 27002:2022. **A norma orienta que o gerenciamento de chaves criptográficas deve incluir processos seguros para uma série de atividades, incluindo a destruição de chaves comprometidas.** Especificamente, o gerenciamento de chaves deve lidar com chaves comprometidas, o que pode incluir a [revogação e destruição dessas chaves](#), **não** apenas o arquivamento.

Além disso, a norma recomenda manter registros e auditorias das atividades relacionadas ao gerenciamento de chaves, assegurando que todas as ações, incluindo a destruição de chaves comprometidas, sejam documentadas.

Portanto, afirmar que chaves comprometidas nunca devem ser destruídas e apenas arquivadas não está alinhado com as práticas recomendadas pela norma.

Errado.

013. (CESGRANRIO/TÉCNICO BANCÁRIO NOVO (CEF)/ADMINISTRATIVA/APLICAÇÃO RS/2024) A ABNT NBR ISO/IEC 27002:2022 fornece um conjunto de referência de controles genéricos de segurança da informação, incluindo orientação para implementação. Uma das definições presentes nessa norma se refere a um incidente, seja previsto ou imprevisto, que causa um desvio não planejado e negativo da expectativa de entrega de produtos e serviços de acordo com os objetivos da organização.

Essa é a definição de

- a) ataque
- b) ameaça
- c) interrupção

- d) vulnerabilidade
- e) violação de segurança da informação



Com base na ABNT NBR ISO/IEC 27002:2022, vamos explorar as definições de cada termo para identificar qual se refere a um incidente que causa um desvio não planejado e negativo:

- a) Errada. **Ataque**: refere-se a uma **tentativa não autorizada, bem-sucedida ou malsucedida, de destruir, alterar, desabilitar, obter acesso a um ativo** ou qualquer tentativa de expor, roubar ou fazer uso não autorizado de um ativo.
- b) Errada. **Ameaça**: causa potencial de um incidente indesejado, que pode resultar em danos a um sistema ou organização.
- c) Certa. **Disrupção**: **incidente, seja previsto ou imprevisto, que causa um desvio, não planejado e negativo da expectativa de entrega de produtos e serviços de acordo com os objetivos da organização.**
- d) Errada. **Vulnerabilidade**: fraqueza de um ativo ou controle que pode ser explorado por uma ou mais ameaças.
- e) Errada. **Violação de segurança da informação**: é um incidente em que a confidencialidade, integridade ou disponibilidade da informação é comprometida. Isso pode incluir acesso não autorizado, destruição ou alteração de dados.

Com base nas definições acima, a opção que melhor se encaixa na descrição de um incidente que causa um desvio não planejado e negativo da expectativa de entrega de produtos e serviços é: **c) Disrupção.**

A disrupção é o termo que descreve um evento que interrompe a continuidade dos negócios e afeta a capacidade de uma organização de atingir seus objetivos.

Letra c.

014. (VUNESP/ANALISTA JUDICIÁRIO (TRF 3ª REGIÃO)/APOIO ESPECIALIZADO/INFORMÁTICA/2023) A norma ABNT NBR ISO/IEC 27002:2022 (Segurança da informação cibernética e proteção à privacidade – Controles de segurança da informação) estabelece, em seu capítulo 5, uma seção sobre inteligência de ameaças, na qual preconiza que tal tipo de inteligência seja dividido ou classificado em três camadas para tratamento de ameaças. Essas três camadas são as inteligências de ameaças

- a) interna, mista e externa.
- b) irrelevante, média e grave.
- c) de sistema, de invasão e de pessoas.
- d) preliminar, de objetivo e de finalização.
- e) estratégica, tática e operacional.



A norma ABNT NBR ISO/IEC 27002:2022, em seu capítulo sobre inteligência de ameaças, classifica a **inteligência de ameaças em três camadas para o tratamento eficaz das ameaças**. Essas camadas são:

e) Estratégica, tática e operacional.

Inteligência Estratégica de Ameaças: Envolve a troca de informações de alto nível sobre o cenário em mudança das ameaças, como tipos de atacantes ou tipos de ataques. Essa camada ajuda a entender o panorama geral das ameaças.

Inteligência Tática de Ameaças: Fornece informações sobre as metodologias dos atacantes, incluindo as ferramentas e tecnologias que eles utilizam. Essa camada foca em como os ataques são realizados.

Inteligência Operacional de Ameaças: Detalha ataques específicos, incluindo indicadores técnicos que podem ser usados para identificar e mitigar ameaças em tempo real.

Essas camadas são projetadas para serem relevantes, perspicazes, contextuais e acionáveis, permitindo que as organizações tomem medidas informadas e eficazes para proteger seus ativos contra ameaças emergentes e existentes.

Letra e.

015. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 é aplicável apenas a grandes organizações, devido à complexidade dos controles de segurança da informação.



A norma é projetada para ser aplicável a organizações de todos os tamanhos e setores, fornecendo um conjunto flexível de controles que podem ser adaptados conforme necessário.

Errado.

016. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 inclui controles específicos para a proteção de dados em trânsito e em repouso.



A norma aborda a proteção de dados em diferentes estados, incluindo medidas para garantir a segurança durante o armazenamento e a transmissão.

Certo.

017. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

De acordo com a norma, a confidencialidade é o único princípio importante a ser considerado na classificação da informação.



A norma destaca a importância de **três princípios: confidencialidade, integridade e disponibilidade**, ao classificar informações.

Errado.

018. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 recomenda que todos os controles de segurança sejam obrigatoriamente implementados em todas as organizações.



A norma fornece um conjunto de controles que devem ser selecionados e implementados **com base nas necessidades específicas e no contexto de cada organização**.

Errado.

019. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A inteligência de ameaças, conforme descrita na norma, deve ser perspicaz e acionável.



A norma enfatiza que a **inteligência de ameaças** deve fornecer uma compreensão clara e permitir ações eficazes para mitigar riscos.

Certo.

020. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 organiza os controles em categorias como controles organizacionais, físicos, de pessoas e tecnológicos.



Os **controles** são categorizados como:

- a) **pessoas**, se eles dizem respeito a pessoas individuais;
- b) **físico**, se eles dizem respeito a objetos físicos;

- c) **tecnológico**, se eles dizem respeito à tecnologia;
d) caso contrário, eles são categorizados como **organizacionais**.

Assim, essas são as principais categorias usadas na norma para estruturar os controles de segurança da informação.

Certo.

021. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma recomenda que a segurança da informação seja tratada exclusivamente como uma questão técnica, sem envolver a alta gestão.



A norma enfatiza a importância do envolvimento da alta gestão no estabelecimento e apoio às políticas de segurança da informação.

Errado.

022. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 sugere que a gestão de identidade e acesso é uma parte crítica da segurança da informação.



A gestão de identidade e acesso é essencial para controlar quem tem acesso a informações e sistemas, sendo um componente chave da segurança.

Certo.

023. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma inclui diretrizes para a implementação de controles de segurança em ambientes de nuvem.



A norma aborda a segurança em diferentes ambientes, incluindo a nuvem, refletindo as práticas modernas de TI.

Certo.

024. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

Os controles de segurança física são irrelevantes para a segurança da informação, segundo a norma.



A segurança física é uma parte importante da segurança da informação, protegendo os ativos físicos e os dados armazenados neles.

Errado.

025. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 não aborda a necessidade de conformidade com leis e regulamentos.



A norma inclui diretrizes para garantir que as organizações estejam em conformidade com as leis e regulamentos aplicáveis.

Errado.

026. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma sugere que a análise de risco deve ser realizada apenas uma vez durante a implementação inicial de um sistema de segurança da informação.



A análise de risco deve ser um processo contínuo, revisado regularmente para refletir mudanças no ambiente de ameaças.

Errado.

027. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma ABNT NBR ISO/IEC 27002:2022 inclui diretrizes para a resposta a incidentes de segurança da informação.



A norma fornece orientações sobre como responder a incidentes de segurança para minimizar o impacto e prevenir recorrências.

Certo.

028. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

A norma recomenda que todos os dados sejam criptografados, independentemente de seu valor ou sensibilidade.



A criptografia deve ser aplicada com base na classificação da informação e na avaliação de riscos, considerando o valor e a sensibilidade dos dados.

Errado.

029. (INÉDITA/2024) Com base na norma ABNT NBR ISO/IEC 27002:2022, julgue o item subsequente.

De acordo com a norma, a segurança da informação deve ser integrada aos processos de negócios da organização.



A integração da segurança da informação nos processos de negócios é fundamental para garantir que as medidas de segurança sejam eficazes e alinhadas com os objetivos organizacionais.

Certo.

REFERÊNCIAS

Quintão, Patrícia L. **Notas de aula. Tecnologia da Informação.** 2024.

ABNT NBR ISO/IEC 27002. Segurança da informação, segurança cibernética e proteção à privacidade — Controles de segurança da informação. Rio de Janeiro, 2022.

NT NBR ISO/IEC 27001:2013, Tecnologia da Informação – Técnicas de segurança – Sistemas de gestão da segurança da informação– Requisitos

ABNT NBR ISO/IEC 27005, Tecnologia da informação – Técnicas de segurança – Gestão de riscos de segurança da informação

ABNT NBR ISO/IEC 27007, Segurança da informação, segurança cibernética e proteção da privacidade – Diretrizes para auditoria de sistemas de gestão da segurança da informação

Abra



caminhos



crie

futuros

gran.com.br

